

An Attack Risk Assessment Model for Network Security Automation

Francesca Coriale

Prof. Daniele Brighenti

Prof. Fulvio Valenza

Prof. Riccardo Sisto



Politecnico
di Torino

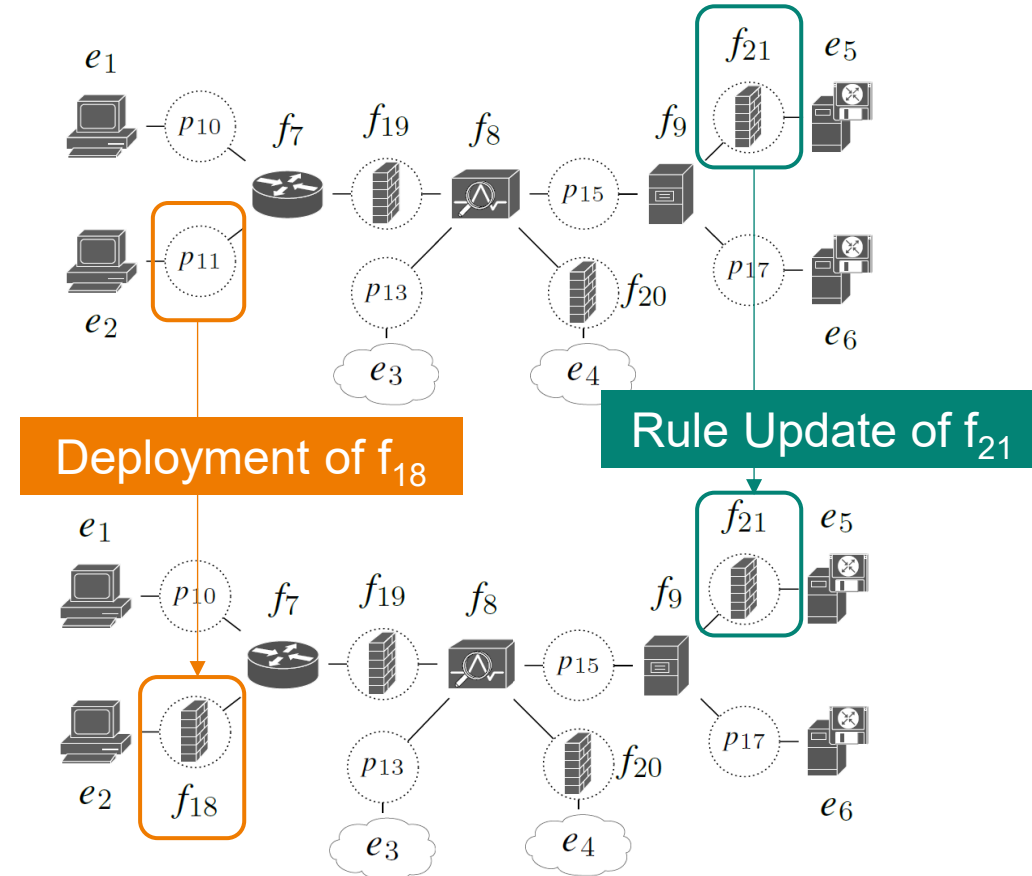


Background

- Proton 2022 report: growth of DDoS attacks with multiple attack vectors and rapid changes within minutes
- Modern systems require constant firewall updates

Possible solution: **FATO** approach

- objective to optimize the scheduling of reconfiguration changes to minimize the number of temporary insecure states

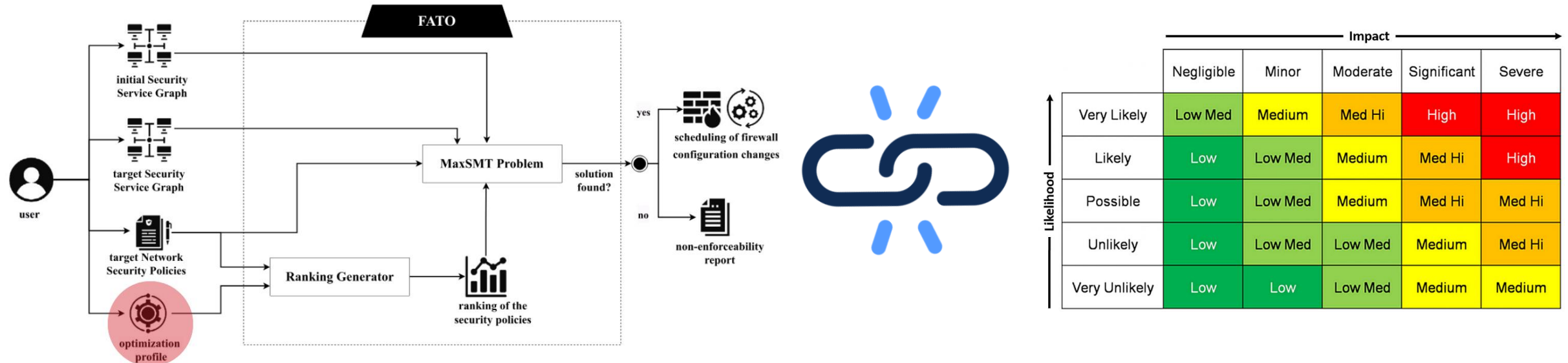


Proton, "A brief update regarding ongoing DDoS incidents," *Proton Blog*, 2022. [Online]. Available: <https://proton.me/blog/a-brief-update-regarding-ongoing-ddos-incidents>

Motivations

- FATO's scheduling model is based on user's preferences
- Multi-attacks scenarios need an objective and attack-related response

Take inspiration from **Risk Assessment** models



Thesis Contribution

To bridge the gap between risk assessment and network security automation



Study of Risk Assessment models



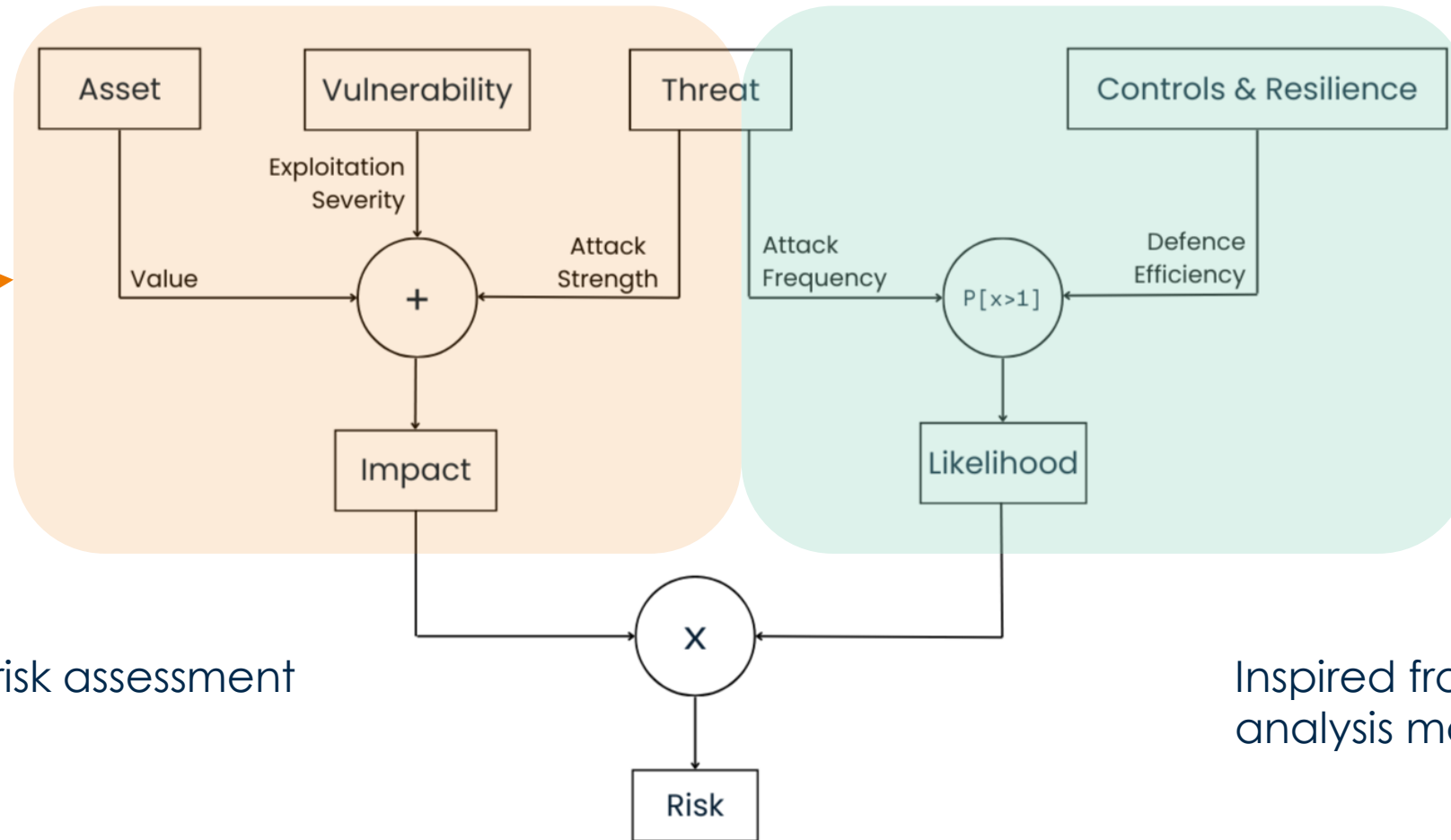
Adaptation of a semi-quantitative risk model to the reaction case



Implementation and validation within the FATO framework in a critical infrastructure

Thesis Contribution

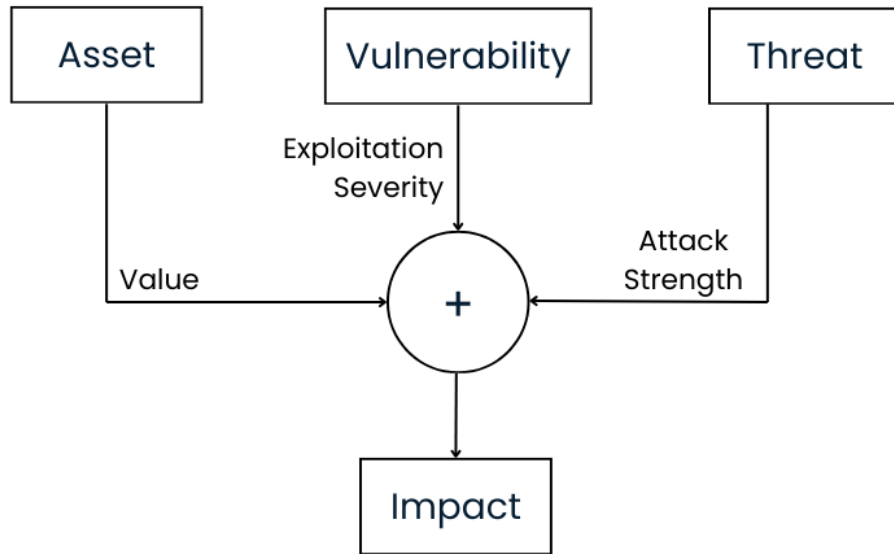
The proposed approach takes inspiration from well-known risk assessment models



Inspired from NIST risk assessment framework

Inspired from Open FAIR risk analysis model

Thesis Contribution: Impact value



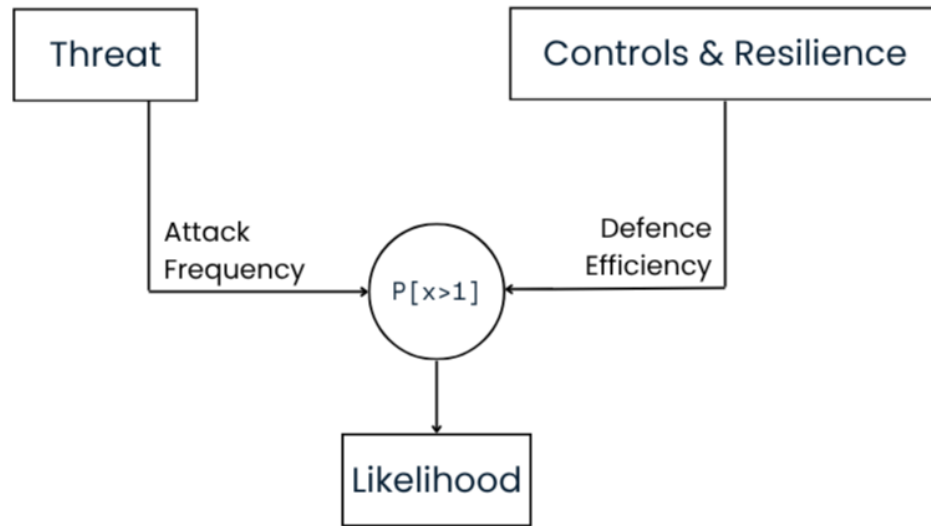
- Asset Value (Business Impact Score)
- Exploitation Severity (CVSS score)
- Attack Strength

$$\delta = \frac{attack - normal}{threshold - normal}$$

The Impact value is the result of:

$$w_1 \cdot Asset\ Value + w_2 \cdot Expl.\ Severity + w_3 \cdot Attack\ Strength$$

Thesis Contribution: Likelihood value



The probability of reoccurrence of an event is a *Poisson distribution*

$$f(\lambda; k) = P[X = k] = \frac{\lambda^k e^{-\lambda}}{k!}$$

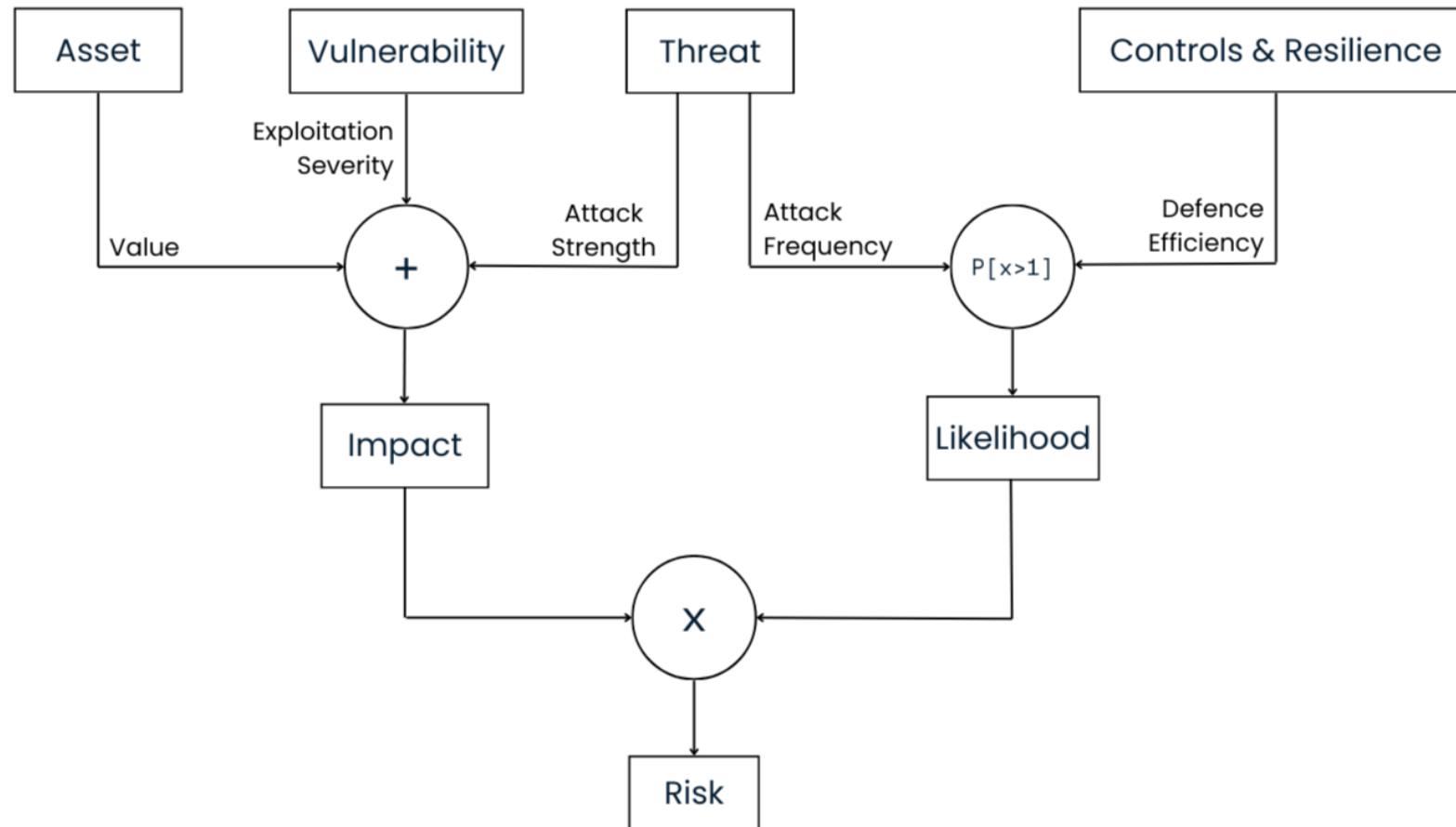
The likelihood of reoccurrence is

$$P[X > 0] = 1 - P[X = 0] = 1 - e^{-\lambda}$$

where $\lambda = \text{Attack Freq.} \times (1 - \text{Defence Eff.})$

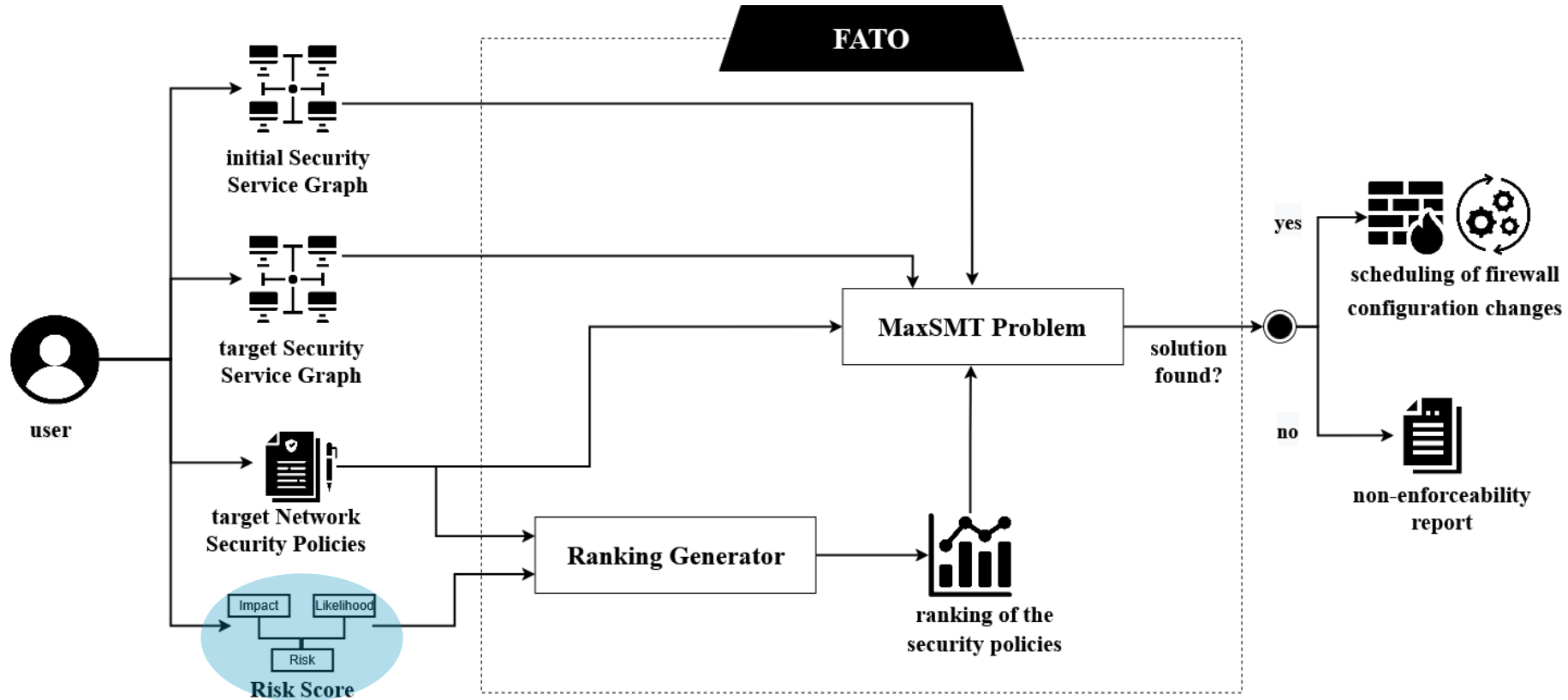
Thesis Contribution: Risk level

The final Risk level is the product of the Impact and the Likelihood



Implementation

The Risk Score model has been included in the FATO's inputs and the formulation of the MaxSMT problem has been adapted

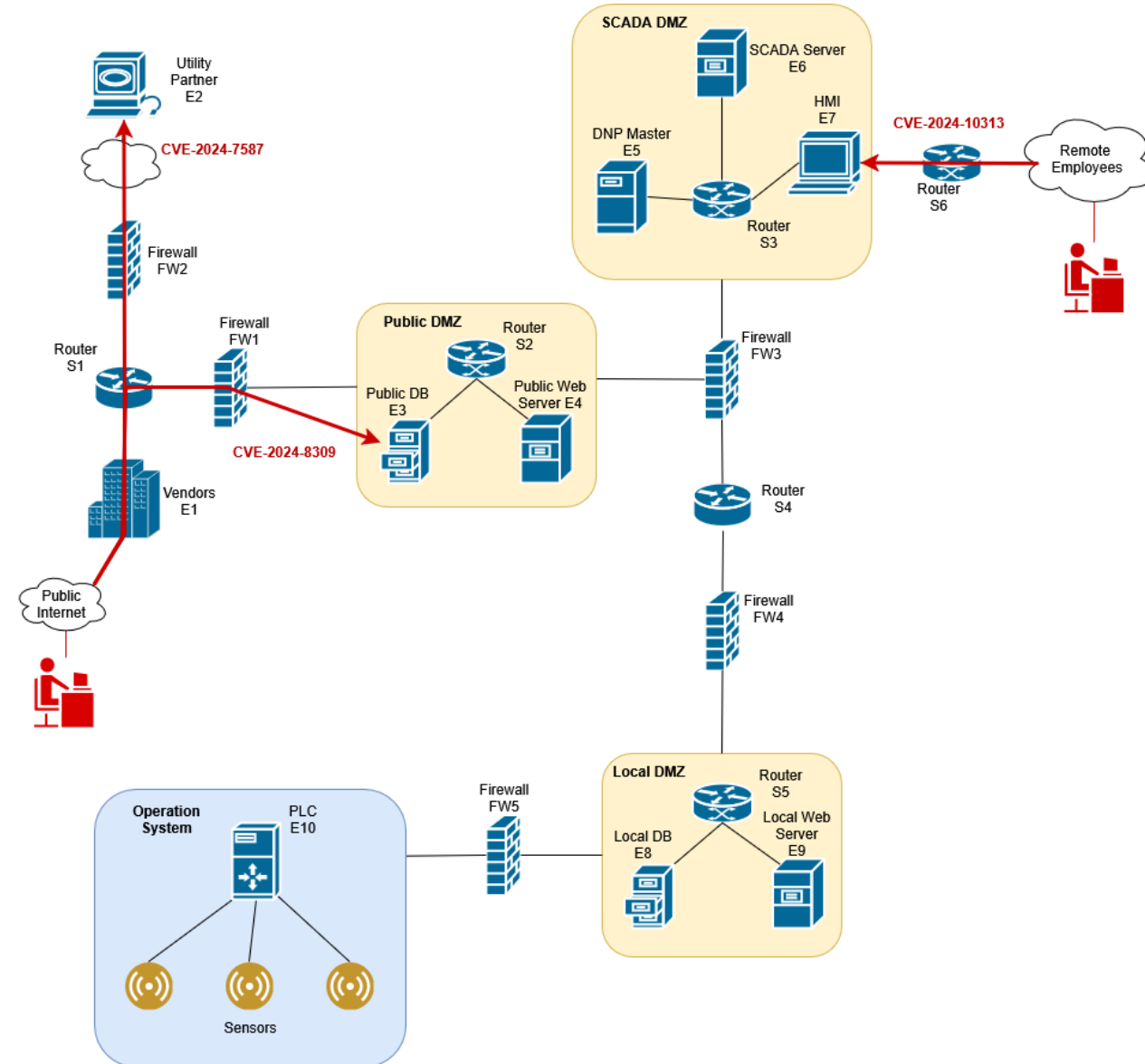


Validation Use Case

SCADA systems are the most used in critical infrastructures

- 2 sources of attacks
- 3 exploitable vulnerabilities

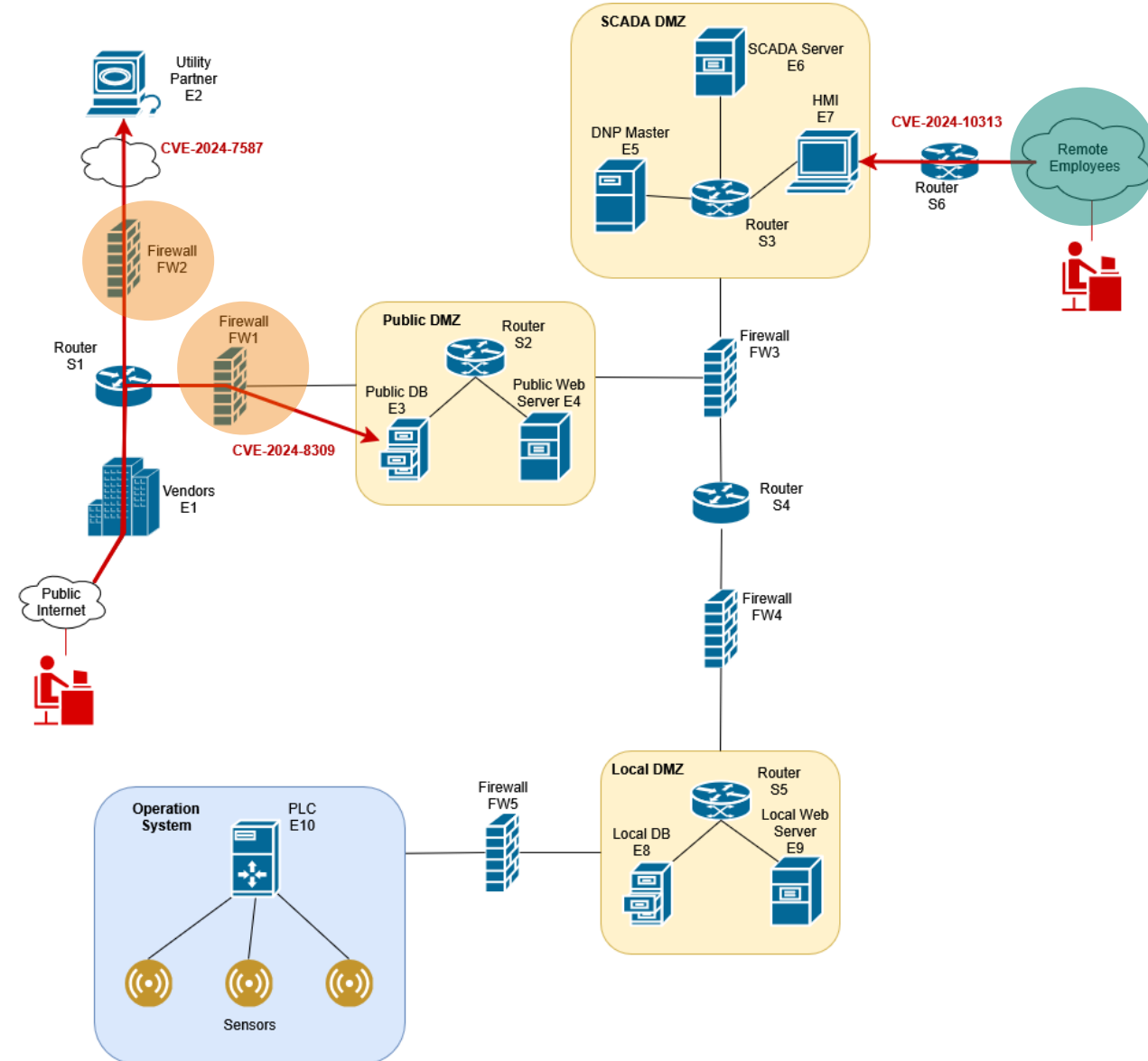
- 1) DDoS attack
- 2) Data exfiltration
- 3) Privilege escalation



Validation Use Case

The final risk level is the result of
Impact × Likelihood

Attack Scenario	Impact value	Likelihood value	Risk Level
Utility Partner	6.9	1.1	7.6
Public Database	4.3	1.8	7.7
HMI	5.6	1.8	10.1



Conclusions & future work

Conclusions:

- Design of a risk-driven approach to optimize the automatic reconfiguration of firewalls during complex attacks.
- Validation on a realistic SCADA testing ground with real-world vulnerabilities.

F. Coriale, F. Valenza, D. Brighenti, "MITO: Multi-attack Impact-aware Transient Optimizer for Firewall Reconfiguration" submitted to Computer Networks (Elsevier)

Future work:

- Application to other automation approaches
- Enhancement by embedding live feeds from threat intelligence platforms

Thank you
for your attention



Politecnico
di Torino

